المدرسة الوطنية العليا للذكاء الاصطناعي وعلوم المعطيات - تارودانت
ÉCOLE NATIONALE SUPÉRIEURE DE L'INTELLIGENCE ARTIFICIELLE
ET SCIENCES DES DONNÉES - TAROUDANT

Université Ibn Zohr

École Nationale Supérieure de l'Intelligence Artificielle et des Sciences des Données

Filière : Sécurité IT et Confiance Numérique

Module : Audit SSI

Rapport Mini Projet

Simulateur d'Audit de Sécurité des SI (Conformité ISO 2700x)

Réalisé par :

EL-GTAY Majda
ELANNAB Oumaima
BENKRIMI Sarra
AMJOUNE Amina
AZROU salma
Fatima ezzahra ELhasnaoui

Encadrée par :

Madame Hasnae L'AMRANI

Année Universitaire : 2025/2026

Table des matières

Introduction Générale **6**

I Contexte et Concepts Théoriques **7**
1 Sécurité des systèmes d'information 7
2 Normes ISO 2700x 7
3 Audit de sécurité de l'information 8

II Analyse des besoins **9**
1 Présentation du projet 9
2 Objectif General 9
3 Objectifs pédagogiques 9
4 Utilisateurs ciblés 10
5 Cahier des charges fonctionnel 10

III Architecture et Conception **11**
1 Standardisation des données 11
1.1 Frontend (interface utilisateur) : 11
1.2 Backend (logique métier et traitement) : 11
1.3 Base de données : 12
2 Architecture Generale – Pattern MVT 13
3 Diagramme de cas d'utilisation 13
4 Diagramme de classe 14

IV Fonctionnalites Detaillees **16**
1 Module Tableau de Bord 16
2 Module Gestion des Scenarios (Administration) 16
3 Module Conduite d'Audit – Coeur Fonctionnel 16
4 Module Rapport d'Audit 17
5 Systeme de Scoring 17
5.1 Bareme de Notation 17
5.2 Interpretation du Score Final 18
6 Donnees Preconfigures 18
6.1 Les 20 Controles ISO Preconfigures 18

6.2 Les 4 Scenarios Sectoriels Preconfigures 19
7 Parcours Utilisateur 19
7.1 Flux Auditeur-Etudiant 20
7.2 Flux Administrateur-Formateur 20

V Démonstration **21**
1 Authentification 21
2 tableau de bord 21
3 Liste des Scénarios d'Audit 22
4 Création et Modification d'un Scénario 23
5 Démarrage et Vue d'Ensemble de l'Audit 23
6 Évaluation d'un Contrôle 24
7 Progression en Temps Réel 26
8 Finalisation de l'Audit 26
9 Rapport d'Audit Final 27

Références **32**

Table des figures

III.1 Architecture 12
III.2 Diagramme de cas d'utilisation 13
III.3 Diagramme de classe 14

IV.1 Logique de scoring 18

V.1 Page de connexion de l'application Learn⇒Audit 21
V.2 Tableau de bord de l'auditeur – vue générale des sessions et statistiques . . 22
V.3 Page de sélection des scénarios d'audit avec filtres par secteur et difficulté . 22
V.4 Interface de création d'un scénario – Étape 1/3 : informations générales de l'entreprise fictive 23
V.5 Interface administrateur – Étape 1/3 : informations générales de l'entreprise fictive 23
V.6 Vue d'ensemble de l'audit – progression et contexte de BoutiqueShop SAS 24
V.7 Liste des 20 contrôles ISO à auditer avec objectif de l'audit 24
V.8 Page d'évaluation du contrôle A.5.1 – Politiques de sécurité de l'information 25
V.9 Feedback immédiat après évaluation – « Correct – 5/5 points attribués » . 25
V.10 Vue d'ensemble après completion – 20/20 contrôles évalués, score 27/100 . 26
V.11 Fin de l'audit – bouton de finalisation et génération du rapport 27
V.12 Rapport d'audit – verdict global Non-Conformité Critique, score 27/100 . . 27
V.13 Répartition de la conformité et tableau des risques ISO 27005 28
V.14 Détail des constatations avec statuts, points et niveaux de risque 28
V.15 Interface web du rapport d'audit avec bouton Telecharger PDF – scenario TechConsult SARL 29
V.16 Rapport PDF genere automatiquement – TechConsult SARL 29

Liste des tableaux

II.1 Fonctionnalités minimales de l'application Learn⇒Audit 10

IV.1 Barème de scoring par contrôle 17
IV.2 Interprétation du score final d'audit 18
IV.3 Les 20 contrôles ISO préconfigúrés 19
IV.4 Les 4 scénarios sectoriels préconfigúrés 19
IV.5 Flux auditeur-étudiant (parcours principal) 20

Introduction Générale

Avec la transformation numérique et l'augmentation des cybermenaces, la sécurité des systèmes d'information est devenue un enjeu majeur pour les organisations. Les entreprises doivent protéger leurs données sensibles, leurs infrastructures informatiques et les informations de leurs clients contre les cyberattaques et les fuites de données.

Pour répondre à ces défis, plusieurs standards internationaux ont été développés, notamment la famille de normes ISO/IEC 27000. La norme ISO/IEC 27001 définit les exigences pour la mise en place d'un Système de Management de la Sécurité de l'Information (SMSI), tandis que la norme ISO/IEC 27002 propose des bonnes pratiques de sécurité. De son côté, la norme ISO/IEC 27005 fournit des lignes directrices pour la gestion des risques liés à la sécurité de l'information.

Dans ce contexte, l'audit de sécurité permet d'évaluer la conformité d'une organisation aux exigences de ces normes et d'identifier les éventuelles faiblesses du système d'information.

Le présent mini-projet, intitulé *Learn ⇒ Audit : ISO 2700x*, vise à développer un simulateur interactif permettant de reproduire les principales étapes d'un audit de sécurité. L'application permet à l'utilisateur d'analyser des contrôles de sécurité, de collecter des preuves et d'évaluer la conformité d'une entreprise fictive.

Ce rapport présente la conception et la réalisation de ce simulateur ainsi que les technologies utilisées et les résultats obtenus.

Chapitre I Contexte et Concepts Théoriques

1. Sécurité des systèmes d'information

La sécurité des systèmes d'information (SSI) est un enjeu crucial pour toutes les organisations modernes. Elle vise à protéger les données, les logiciels, les infrastructures et les services contre les cybermenaces, les fuites d'informations ou les pannes systèmes.

Trois principes fondamentaux guident la SSI :

- **Confidentialité :**les informations sensibles ne doivent être accessibles qu'aux personnes autorisées.
- **Intégrité** les informations doivent rester exactes et ne pas être altérées sans autorisation.
- **Disponibilité** : les informations et services doivent être accessibles aux utilisateurs autorisés lorsque nécessaire.

2. Normes ISO 2700x

La famille de normes ISO/IEC 27000 constitue un cadre international pour la gestion de la sécurité de l'information. Les normes principales pour notre projet sont :

- **ISO/IEC 27001 :**définit les exigences pour établir et gérer un Système de Management de la Sécurité de l'Information (SMSI), permettant d'identifier, d'évaluer et de traiter les risques liés à la sécurité des informations.
- **ISO/IEC 27002** : propose un ensemble de contrôles et de bonnes pratiques pour protéger les actifs informationnels, couvrant des domaines comme la gestion des accès, la cryptographie, la sécurité physique et la gestion des incidents.
- **ISO/IEC 27005** : fournit des lignes directrices pour la gestion des risques de sécurité de l'information, incluant l'identification des risques, l'évaluation de leur probabilité et impact, et la définition de mesures de traitement adaptées.

Ces normes servent de référence pour mesurer la sécurité et la conformité des systèmes d'information dans les organisations.

3. Audit de sécurité de l'information

L'audit de sécurité est un processus structuré qui permet d'évaluer la conformité d'un système d'information par rapport aux normes et aux politiques en vigueur. Ses principaux objectifs sont :

- Vérifier l'application effective des contrôles de sécurité.
- Identifier les vulnérabilités et les non-conformités.
- Proposer des recommandations pour renforcer la sécurité.

Un audit de sécurité comprend généralement les étapes suivantes :

- Planification : définir les objectifs, le périmètre et les ressources de l'audit.
- Collecte de preuves : examiner les politiques, procédures, configurations systèmes et journaux (logs).
- Évaluation des contrôles : analyser la conformité des mesures de sécurité mises en place.
- Rédaction du rapport : synthétiser les résultats, présenter les non-conformités et proposer des recommandations.

Dans le cadre du mini-projet Learn Audit : ISO 2700x, ces concepts sont appliqués via un simulateur interactif. L'utilisateur peut ainsi se familiariser avec les étapes d'un audit ISO 2700x dans un environnement pédagogique sécurisé.

Chapitre II Analyse des besoins

1. Présentation du projet

Le mini-projet **Learn Audit : ISO 2700x** vise à concevoir un **simulateur interactif d'audit de sécurité** . L'objectif est de permettre aux étudiants et aux futurs auditeurs de se familiariser avec les normes ISO 2700x et de comprendre le déroulement d'un audit de conformité dans un environnement pédagogique et sécurisé. Le simulateur reproduit un scénario d'audit pour une entreprise fictive, où l'utilisateur doit analyser différents contrôles de sécurité, collecter des preuves et évaluer la conformité des processus et systèmes par rapport aux normes ISO 27001, 27002 et 27005.

2. Objectif General

Learn=>Audit est une application web pedagogique de type serious game destinee a former les futurs auditeurs de securite des SI. Elle simule des situations reelles d'audit de conformite basees sur les normes ISO 2700x, permettant aux apprenants de pratiquer les etapes cles d'un audit sans risque.

3. Objectifs pédagogiques

Le simulateur doit permettre :

- Comprendre les exigences ISO 27001, 27002 et 27005 et leur articulation
- Maitriser la methodologie d'audit : collecte de preuves, evaluation, documentation
- Evaluer la conformite d'un SI a partir de preuves techniques et organisationnelles
- Appliquer la gestion des risques ISO 27005 (probabilite x gravite) sur les non-conformites
- Rediger des recommandations correctives pertinentes et actionnables
- Generer et interpreter un rapport d'audit synthetique avec indicateurs

4. Utilisateurs ciblés

Le simulateur est conçu pour :

- **Les étudiants et stagiaires en cybersécurité**qui souhaitent se former aux audits ISO 2700x.
- **Les enseignants et formateurs,** : qui peuvent l'utiliser comme outil pédagogique.
- **Les auditeurs débutants,** pour se familiariser avec les étapes et méthodologies d'un audit réel.

5. Cahier des charges fonctionnel

Les besoins fonctionnels principaux sont résumés comme suit :

Fonctionnalité	**Description**
Scénario d'entreprise	Présentation d'une entreprise fictive et de son contexte organisationnel.
Sélection des contrôles ISO	Affichage et description de 10 à 15 contrôles ISO 27002.
Collecte de preuves	Interaction avec le simulateur pour obtenir des preuves simulées.
Évaluation de la conformité	Jugement des contrôles comme conformes ou non-conformes.
Gestion des risques simplifiée	Évaluation de la probabilité et de la gravité des risques associés.
Rapport automatique	Génération d'un rapport synthétique et exportable des résultats d'audit.
Système de progression / score	Suivi de l'avancement de l'utilisateur et notation de ses performances.

TABLE II.1 – Fonctionnalités minimales de l'application Learn⇒Audit

Chapitre III Architecture et Conception

1. Standardisation des données

Le simulateur d'audit Learn Audit : ISO 2700x a été conçu selon une architecture client-serveur, permettant une interaction dynamique entre l'utilisateur et le système. Cette architecture permet de séparer l'interface utilisateur, la logique métier et la gestion des données, ce qui facilite la maintenance et l'évolution de l'application.

L'architecture comprend trois composants principaux :

1.1 Frontend (interface utilisateur) :

Le Frontend représente la partie visible de l'application avec laquelle l'utilisateur interagit directement. Il a été développé en utilisant HTML5, CSS3 et JavaScript Vanilla, ce qui permet de créer une interface simple, interactive et accessible depuis un navigateur web. Le frontend permet notamment de :

- Naviguer dans l'application et accéder aux différentes fonctionnalités du simulateur.
- Consulter le scénario d'entreprise fictive à auditer.
- Visualiser les contrôles de sécurité issus des normes ISO 2700x.
- Collecter des preuves simulées sous forme de documents, logs ou configurations.
- Évaluer la conformité des contrôles et saisir des commentaires.
- Afficher le rapport d'audit généré à la fin de la simulation.

1.2 Backend (logique métier et traitement) :

Le Backend constitue le cœur de l'application. Il a été développé avec le framework Django 4.2 en utilisant le langage Python 3.12. Django permet de structurer efficacement l'application selon le modèle MVC (Model-View-Controller) et de gérer les différentes fonctionnalités du simulateur. Le backend assure plusieurs rôles essentiels :

- Gestion des scénarios d'audit et des informations relatives à l'entreprise fictive.
- Traitement des interactions entre l'utilisateur et l'application.
- Gestion des contrôles ISO et des preuves associées.

— Enregistrement des évaluations de conformité effectuées par l'utilisateur.
— Calcul du score ou du niveau de conformité global.
— Préparation des données nécessaires à la génération du rapport d'audit.

L'utilisation de Django permet également d'assurer une bonne sécurité de l'application et de faciliter son évolution future.

1.3 Base de données :

La base de données permet de stocker l'ensemble des informations nécessaires au fonctionnement du simulateur. Durant la phase de développement, la base de données SQLite a été utilisée en raison de sa simplicité d'installation et de configuration. Pour un déploiement en production, une base de données PostgreSQL peut être utilisée afin de bénéficier de meilleures performances, d'une meilleure gestion des volumes de données et d'une plus grande fiabilité.

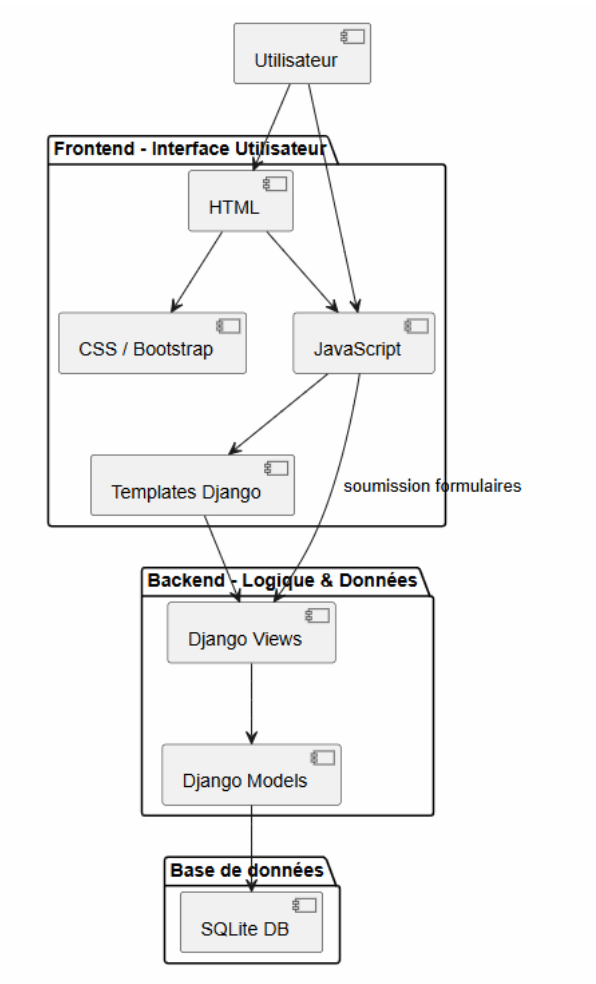

FIGURE III.1 – Architecture

2. Architecture Generale – Pattern MVT

L'application suit le pattern MVT (Model-View-Template) de Django, organise en 5 couches distinctes avec une separation claire des responsabilites. Cette architecture garantit la maintenabilite du code et facilite les evolutions futures.

3. Diagramme de cas d'utilisation

Ce diagramme UML de cas d'utilisation représente l'ensemble des interactions entre les acteurs du système et les fonctionnalités de l'application.

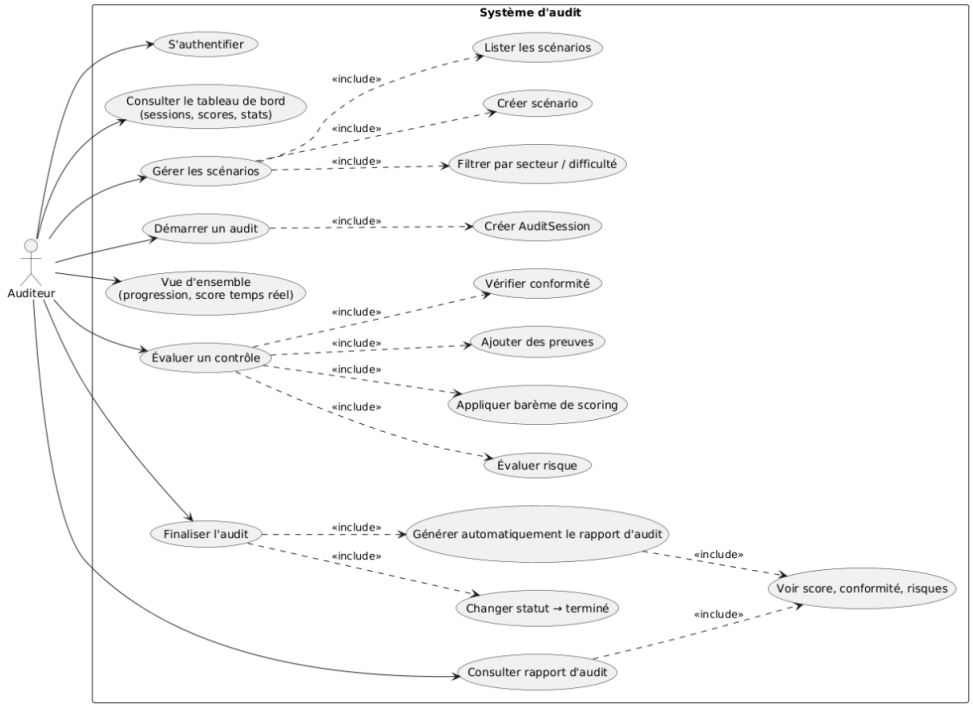

FIGURE III.2 – Diagramme de cas d'utilisation

Cas d'utilisation de l'Auditeur L'auditeur dispose de six cas d'utilisation principaux :

- S'inscrire / Se connecter : point d'entrée obligatoire pour accéder au système.
- Consulter le tableau de bord :visualisation des sessions en cours, scores et statistiques personnelles.
- Consulter les scénarios (filtrer par secteur/difficulté) :sélection du scénario à auditer.
- Démarrer l'audit : qui dépend directement de la consultation des scénarios.
- Voir la progression (score en temps réel) : suivi dynamique pendant la conduite de l'audit.
- Consulter le rapport (score, conformité, risques) : accessible après la finalisation de l'audit.

— Définir les informations du scénario : nom de l'entreprise fictive, secteur, difficulté, contexte.
— Ajouter les preuves : création des preuves simulées avec leur hint de conformité.
— Consulter le rapport (score, conformité, risques) : accessible après la finalisation de l'audit.

Le cas d'utilisation Finaliser l'audit nécessite d'avoir complété Évaluer le contrôle, qui lui-même inclut trois sous-cas d'utilisation fondamentaux :

— Collecter les preuves : consultation des preuves simulées (documents, logs, configs, entretiens).
— Évaluer la conformité : jugement conforme / partiel / non conforme / non applicable.
— Évaluer le risque : application de la matrice ISO 27005 (probabilité × gravité).

4. Diagramme de classe

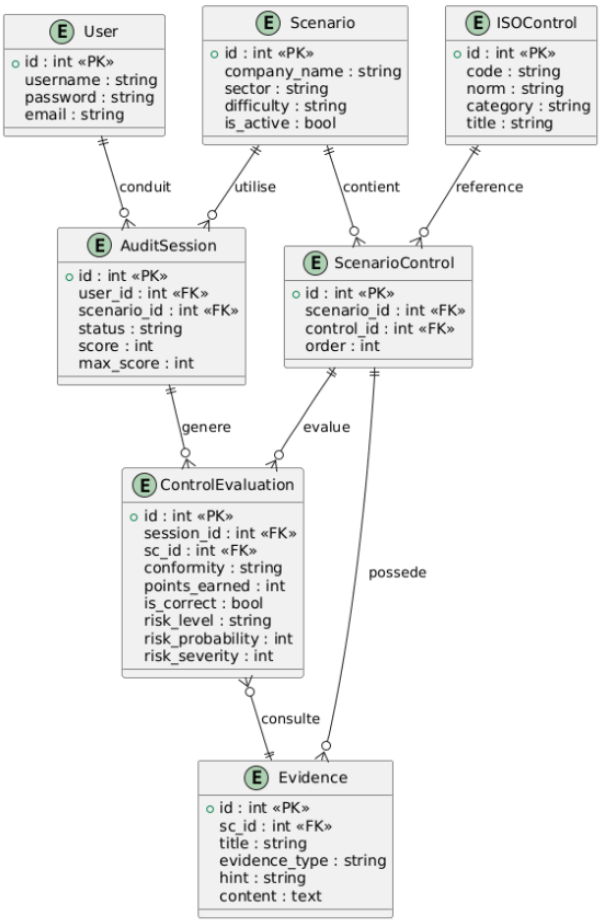

FIGURE III.3 – Diagramme de classe

Les Entités

- User : L'utilisateur authentifié (auditeur ou administrateur). Contient les informations de connexion de base.
- Scenario : L'entreprise fictive à auditer, caractérisée par son secteur, sa difficulté et son statut de visibilité (isactive).
- ISOControl : Un contrôle ISO réutilisable (27001/27002/27005), identifié par son code, sa norme et sa catégorie.
- ScenarioControl :Table de liaison entre Scenario et ISOControl. Elle permet d'associer librement des contrôles à un scénario avec un ordre d'affichage défini.
- AuditSession : La session de travail d'un utilisateur sur un scénario donné. Elle suit le statut (en cours/terminé), le score cumulé et le score maximum.
- ControlEvaluation : L'entité centrale. Elle enregistre le jugement de l'auditeur sur un contrôle : conformité choisie, points obtenus, correction, niveau de risque ISO 27005 (probabilité $\times$ gravité).
- Evidence : La preuve simulée attachée à un contrôle d'un scénario. Elle contient le contenu textuel et le hint (réponse correcte attendue) utilisé par le système de scoring.

Chapitre IV Fonctionnalites Detaillees

1. Module Tableau de Bord

Page d'accueil personnalisee apres connexion, offrant une vue synthetique de l'activite de l'auditeur.

- Sessions d'audit en cours avec barre de progression et bouton 'Continuer'
- 5 derniers audits termines avec scores et liens vers les rapports
- Statistiques globales : total audits, en cours, termines, score moyen
- Lien rapide vers la liste des scenarios disponibles

2. Module Gestion des Scenarios (Administration)

Workflow en 3 etapes permettant aux formateurs de creer des scenarios d'audit complets et personnalises.

- Etape 1 : Informations entreprise – nom, secteur, taille, contexte, objectif d'audit
- Etape 2 : Selection dans le catalogue filtrable de 20 controles ISO (filtre par norme et categorie)
- Etape 3 : Ajout de preuves par controle avec hint cache (document, config, log, entretien, observation)
- Modification, suppression avec confirmation des scenarios existants
- Activation/desactivation de la visibilite d'un scenario (isactive)

3. Module Conduite d'Audit – Coeur Fonctionnel

Module principal de l'application. L'auditeur parcourt les 20 controles du scenario un par un, de facon interactive et progressive.

- Vue d'ensemble : progression globale, score en temps reel, statut par controle
- Navigation controle par controle avec fleches precedent/suivant
- Evaluation : conforme / partiellement conforme / non conforme / non applicable

— Justification textuelle obligatoire et recommandation de traitement
— Evaluation des risques ISO 27005 : probabilite (1-5) x gravite (1-5)
— Feedback immediat apres soumission : correct/incorrect + reponse attendue

4. Module Rapport d'Audit

Generation automatique d'un rapport complet a la finalisation de l'audit. Ce rapport synthetise toutes les evaluations et calcule les statistiques de conformite.

— Verdict global : Bonne Conformite / Conformite Partielle / Non-Conformite Critique
— Score global sur 100 avec barre de progression coloree
— 4 compteurs : controles conformes, non conformes, partiels, non applicables
— Tableau detaille de chaque constatation avec justification et recommandation
— Tableau des risques identifies (controle, probabilite, gravite, niveau de risque)
— Metadonnees completes : auditeur, date, entite auditee, secteur, referentiel

5. Systeme de Scoring

5.1 Bareme de Notation

Le systeme de scoring recompense la capacite de l'auditeur a identifier correctement l'etat de conformite d'un controle. Les points sont attribues uniquement si la reponse correspond au hint majoritaire des preuves associees au controle evalue.

Réponse	**Points**	**Condition**
Conforme	**5 pts**	Réponse correcte : correspond au hint majoritaire
Partiellement conforme	**2 pts**	Réponse correcte : correspond au hint majoritaire
Non conforme	**0 pt**	Réponse correcte : correspond au hint majoritaire
Non applicable	**1 pt**	Réponse correcte : correspond au hint majoritaire
Réponse incorrecte	**1 pt**	Ne correspond pas au hint majoritaire (quel que soit le choix)

TABLE IV.1 – Barème de scoring par contrôle

Score maximum : 20 contrôles × 5 pts = 100 points

5.2 Interpretation du Score Final

Score	Verdict	Interprétation
70 pts et plus (70%+)	**Bonne Conformité**	Organisation satisfaisante – maturité sécurité élevée
40 a 69 pts (40%-69%)	**Conformité Partielle**	Efforts significatifs nécessaires – plan d'amélioration requis
0 a 39 pts (moins de 40%)	**Non-Conformité Critique**	Actions correctives urgentes – risques élevés identifiés

TABLE IV.2 – Interprétation du score final d'audit

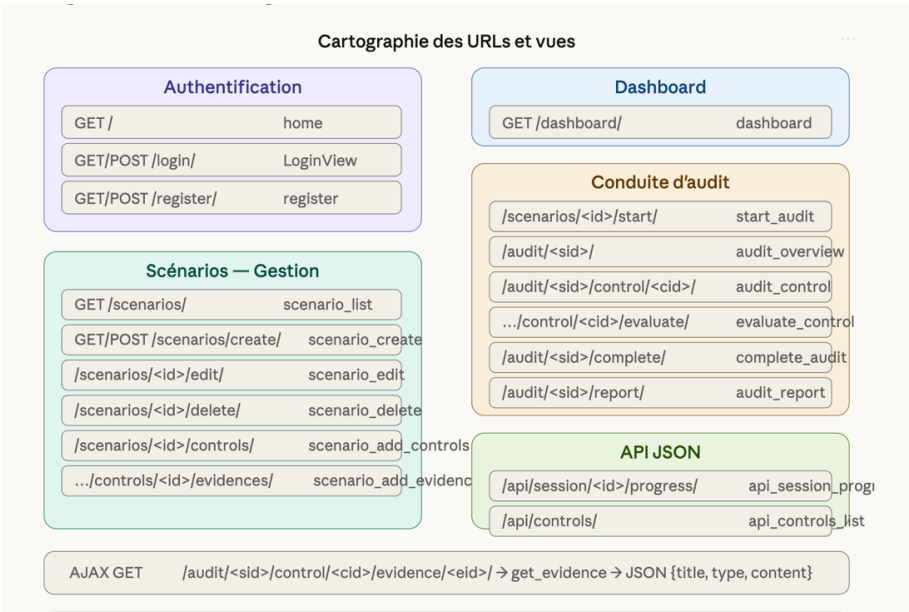

FIGURE IV.1 – Logique de scoring

6. Donnees Preconfigures

6.1 Les 20 Controles ISO Preconfigures

Le script populate-data.py charge 20 controles couvrant les principaux domaines de la norme ISO 27002 :2022 et ISO 27001. Ces controles sont reutilisables dans tous les scenarios.

Code	Norme	Catégorie	Titre du Contrôle
A.5.1	27002	Politique	Politiques de sécurité de l'information
A.5.2	27002	Politique	Rôles et responsabilités en sécurité
A.5.3	27002	Organisation	Séparation des tâches
A.6.1	27002	RH	Sécurité avant l'embauche
A.6.2	27002	RH	Sensibilisation, éducation et formation
A.7.1	27002	Actifs	Inventaire des actifs
A.7.2	27002	Actifs	Classification de l'information
A.8.1	27002	Accès	Politique de contrôle d'accès
A.8.2	27002	Accès	Gestion des identifiants d'accès
A.8.3	27002	Accès	Gestion des droits d'accès privilégiés
A.8.5	27002	Accès	Authentification sécurisée
A.8.7	27002	Opérations	Protection contre les logiciels malveillants
A.8.8	27002	Opérations	Gestion des vulnérabilités techniques
A.8.9	27002	Opérations	Gestion des configurations
A.8.11	27002	Opérations	Suppression des données
A.8.12	27002	Opérations	Prévention de la fuite de données
A.8.16	27002	Incidents	Surveillance des activités
A.8.24	27002	Cryptographie	Utilisation de la cryptographie
A.5.29	27001	Continuité	Sécurité en cas de perturbation
A.5.31	27001	Conformité	Exigences légales et contractuelles

Table IV.3 – Les 20 contrôles ISO préconfigúrés

6.2 Les 4 Scenarios Sectoriels Preconfigures

Quatre scenarios d'audit complets sont disponibles immediatement apres l'execution de la commande populate-data, couvrant des secteurs varies et des niveaux de difficulte differents.

Scénario	Secteur	Difficulté	Profil de Conformité
Hôpital Saint-Luc	Santé / HDS	Avancé	14 NC, 5 partiels, 1 conforme – Gravité élevée
BoutiqueShop SAS	E-Commerce	Intermédiaire	Mix équilibré – 1 NC critique (patch management)
SecurePay SA	Banque / Fintech	Avancé	Quasi tout conforme – 1 partiel (NIS2 en cours)
TechConsult SARL	Services	Débutant	20 non-conformes – Idéal pour les débutants

Table IV.4 – Les 4 scénarios sectoriels préconfigúrés

7. Parcours Utilisateur

7.1 Flux Auditeur-Etudiant

Le parcours principal de l'application guide l'etudiant depuis son inscription jusqu'a la consultation du rapport d'audit final.

Etape	Page / Action	Description
1	Inscription / Connexion	Création d'un compte ou connexion a un compte existant
2	Tableau de bord	Consultation des sessions en cours et des audits terminés
3	Liste des scénarios	Filtrage par secteur et difficulté, choix d'un scénario
4	Démarrage	Création d'une `AuditSession` avec `score=0`, `max_score=nb_ctrl*5`
5	Vue d'ensemble audit	Tableau de bord du scénario : progression, statut des contrôles
6	Contrôle 1..20	Lecture description + objectif + conseils du contrôle courant
7	Collecte de preuves	Chargement AJAX des preuves disponibles, lecture du contenu
8	Évaluation	Choix conformité + justification + risque ISO 27005 + recommandation
9	Scoring immédiat	Comparaison au hint + attribution points + feedback correct/incorrect
10	Répétition 6-9	Jusqu'à évaluation des 20 contrôles du scénario
11	Finalisation	Passage du statut `en_cours` à `termine`, horodatage `completed_at`
12	Rapport d'audit	Consultation du rapport complet avec verdict et statistiques

Table IV.5 – Flux auditeur-étudiant (parcours principal)

7.2 Flux Administrateur-Formateur

- **Etape 1** : Vue de tous les scénarios avec boutons Gérer / Modifier / Supprimer
- **Etape 2** : Formulaire de création – nom entreprise, secteur, difficulté, contexte, objectif
- **Etape 3** : Sélection dans le catalogue de 20 contrôles ISO (filtre norme/catégorie)
- **Etape 4** : Ajout de preuves par contrôle (titre, type, contenu, hint)
- **Etape 5** : Activation du scénario (`is_active=True`) pour le rendre visible aux auditeurs

Chapitre V Démonstration

1. Authentification

L'accès à l'application nécessite une authentification préalable. L'utilisateur saisit son nom d'utilisateur et son mot de passe pour accéder à ses sessions d'audit. Un lien d'inscription est disponible pour les nouveaux utilisateurs.

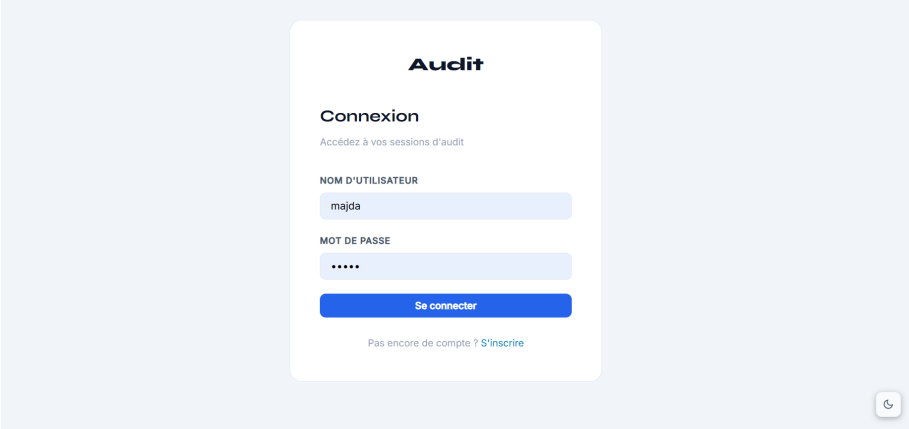

FIGURE V.1 – Page de connexion de l'application Learn⇒Audit

2. tableau de bord

Après connexion, l'auditeur accède à son tableau de bord personnel. Cette page affiche une vue synthétique de son activité : le nombre d'audits réalisés, les sessions en cours, les audits terminés ainsi que son score moyen global. Les audits en cours et terminés sont listés avec leurs scores respectifs, permettant à l'auditeur de suivre sa progression et d'accéder directement aux rapports générés.

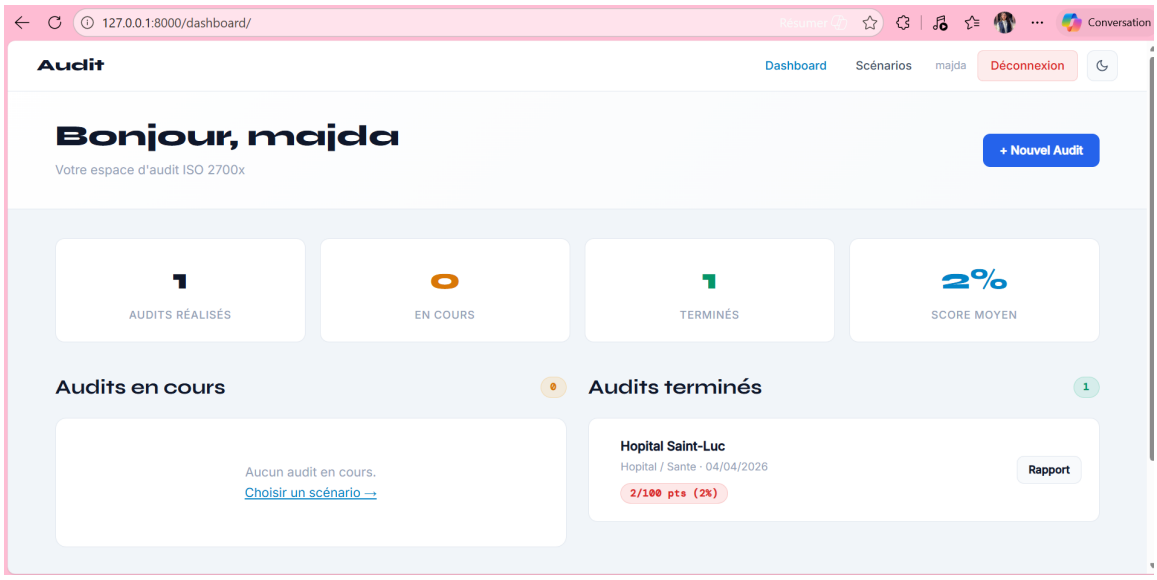

FIGURE V.2 – Tableau de bord de l'auditeur – vue générale des sessions et statistiques

3. Liste des Scénarios d'Audit

La page des scénarios présente l'ensemble des entreprises fictives disponibles à auditer. L'auditeur peut filtrer les scénarios par **secteur** (Hôpital/Santé, E-Commerce, Banque/Finance, etc.) et par **niveau de difficulté** (Débutant, Intermédiaire, Avancé). Chaque carte affiche le nom de l'entreprise, son secteur, sa taille, une brève description du contexte d'audit ainsi que le nombre de contrôles à évaluer (20 contrôles). Un bouton « Démarrer l'audit » permet de lancer une nouvelle session.

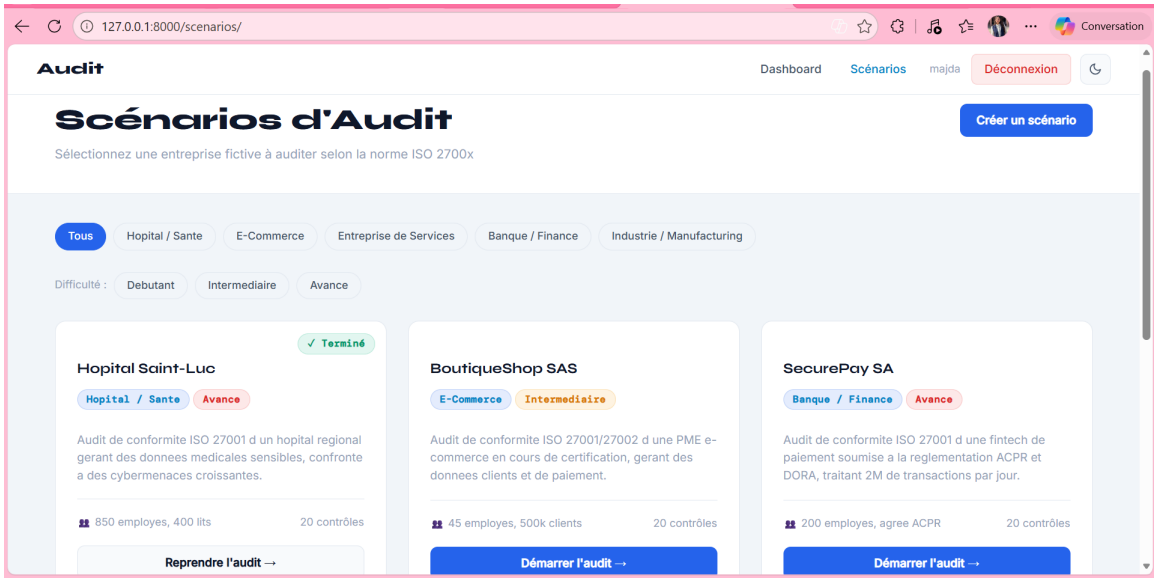

FIGURE V.3 – Page de sélection des scénarios d'audit avec filtres par secteur et difficulté

4. Création et Modification d'un Scénario

L'interface d'administration permet au formateur de créer ou modifier un scénario en **3 étapes** guidées, matérialisées par une barre de progression en haut de la page. La première étape concerne les **informations générales** de l'entreprise fictive : nom, taille, titre du scénario, secteur et niveau de difficulté.

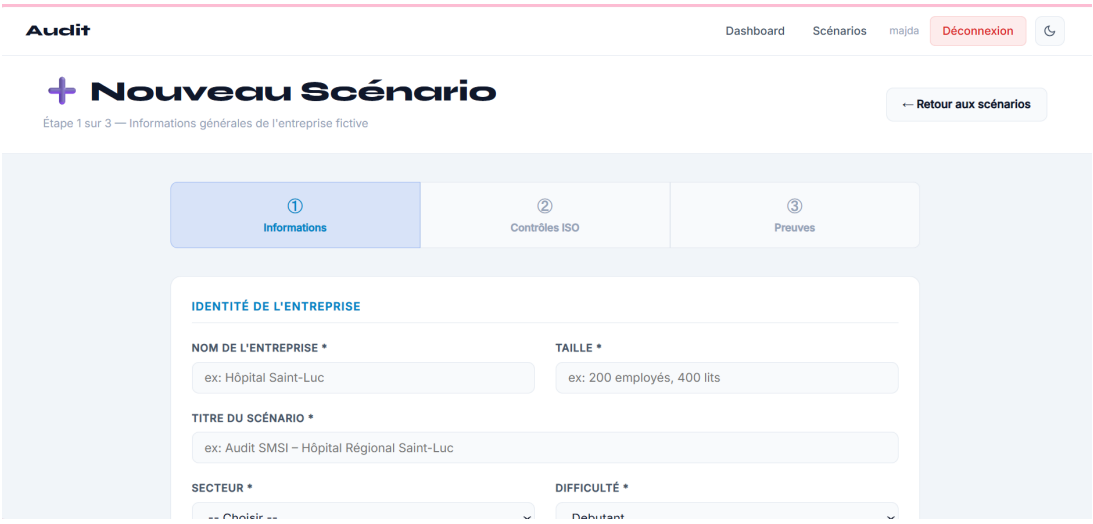

FIGURE V.4 – Interface de création d'un scénario – Étape 1/3 : informations générales de l'entreprise fictive

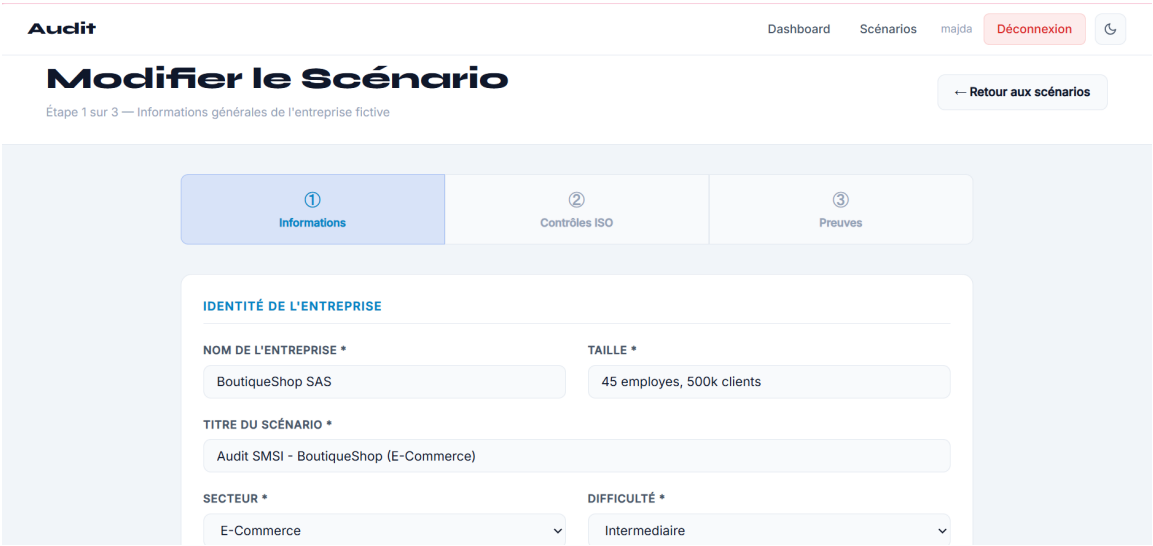

FIGURE V.5 – Interface administrateur – Étape 1/3 : informations générales de l'entreprise fictive

5. Démarrage et Vue d'Ensemble de l'Audit

Après avoir sélectionné le scénario **BoutiqueShop SAS**, l'auditeur accède à la vue d'ensemble de l'audit. Cette page affiche la progression en temps réel (0/20 contrôles évalués,

score 0/100 points), le contexte de l'entreprise fictive ainsi que l'objectif de l'audit. Un message de confirmation indique que la session a bien été démarrée.

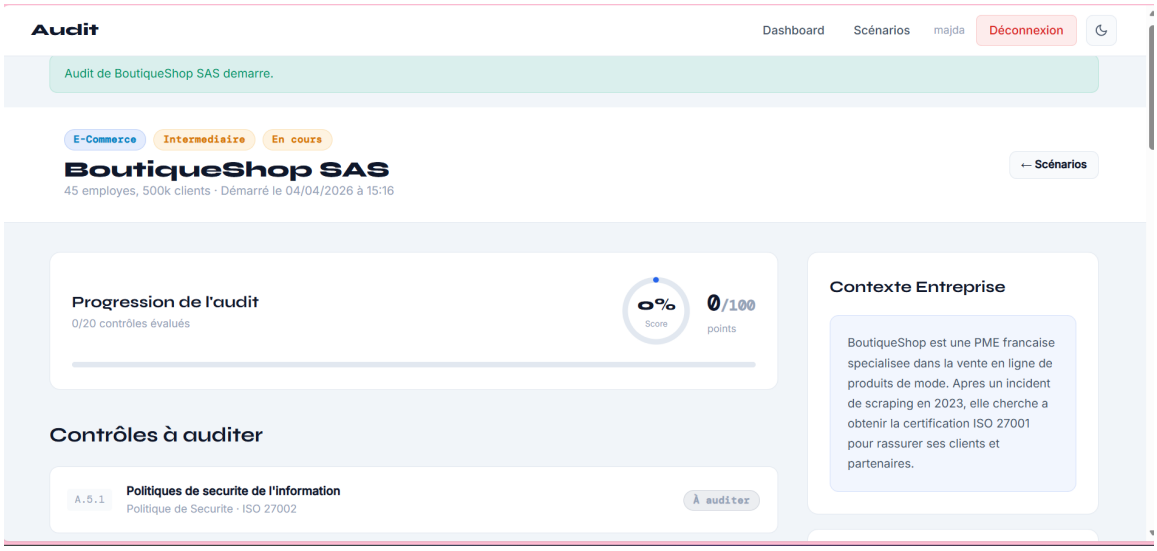

FIGURE V.6 – Vue d'ensemble de l'audit – progression et contexte de BoutiqueShop SAS

La liste des 20 contrôles à auditer est affichée dans l'ordre défini par l'administrateur. Chaque contrôle indique son code ISO, son titre, sa catégorie et son statut (« À auditer »). Le panneau latéral droit rappelle l'objectif de l'audit : évaluer la maturité de la sécurité de BoutiqueShop en vue de sa certification ISO 27001.

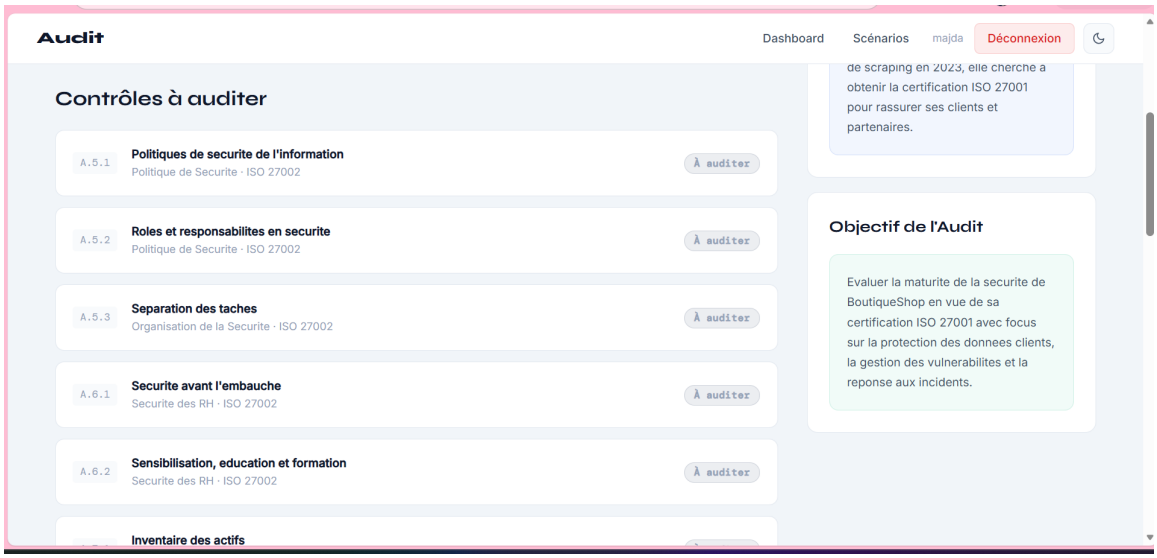

FIGURE V.7 – Liste des 20 contrôles ISO à auditer avec objectif de l'audit

6. Évaluation d'un Contrôle

Pour chaque contrôle, l'auditeur dispose d'une fiche complète présentant la **description du contrôle**, son **objectif** et des **conseils d'audit** pour orienter son évaluation. Le pan-

neau latéral droit permet de sélectionner le statut de conformité (« Conforme », « Non Conforme », « Partiellement Conforme » ou « Non Applicable ») et de saisir une justification. La navigation contrôle par contrôle est assurée par les boutons « Précédent » et « Suivant ».

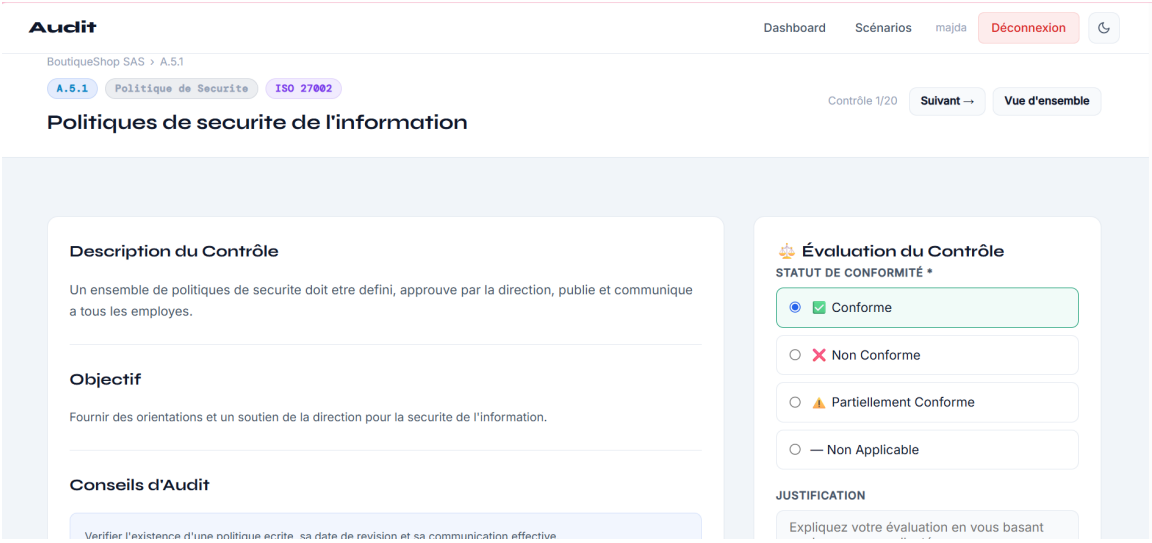

FIGURE V.8 – Page d'évaluation du contrôle A.5.1 – Politiques de sécurité de l'information

Après soumission de l'évaluation, un **feedback immédiat** est affiché en haut de la page indiquant si la réponse est correcte ou incorrecte ainsi que les points attribués. Dans l'exemple ci-dessous, la réponse « Conforme » pour le contrôle A.5.1 est correcte, ce qui a permis d'obtenir **5/5 points**. L'application passe automatiquement au contrôle suivant (A.5.2).

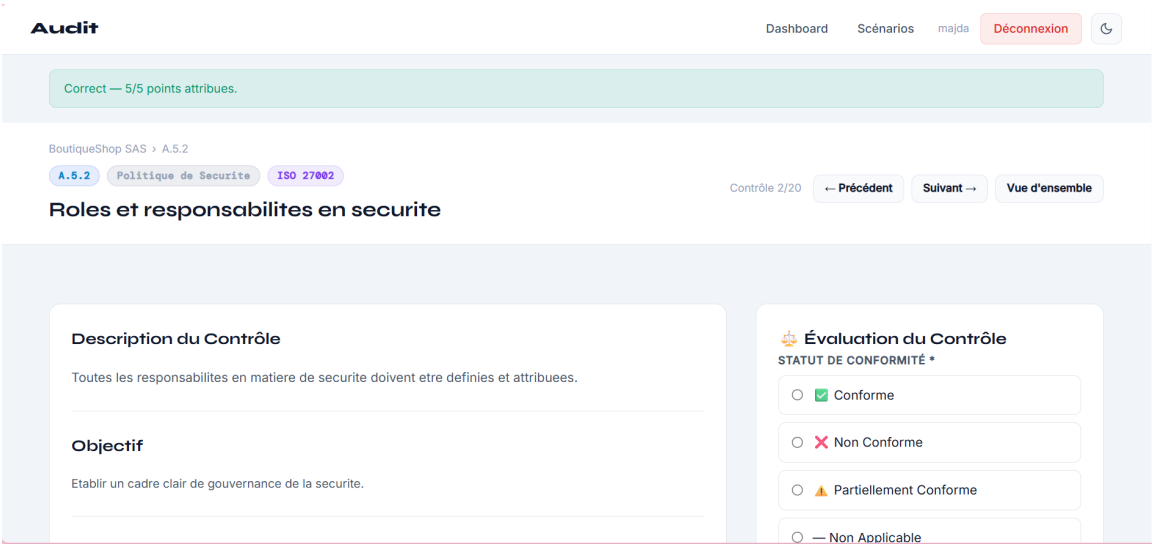

FIGURE V.9 – Feedback immédiat après évaluation – « Correct – 5/5 points attribués »

7. Progression en Temps Réel

Une fois les 20 contrôles évalués, la vue d'ensemble se met à jour automatiquement et affiche la progression complète de l'audit. Dans cet exemple, l'auditeur a obtenu un score de **27/100 points (27%)**. La liste des contrôles affiche le statut de chaque évaluation avec le nombre de points obtenus : « Conforme » pour le contrôle A.5.1 (5/10 pts) et « Non Conforme » pour le contrôle A.5.2 (0/10 pts).

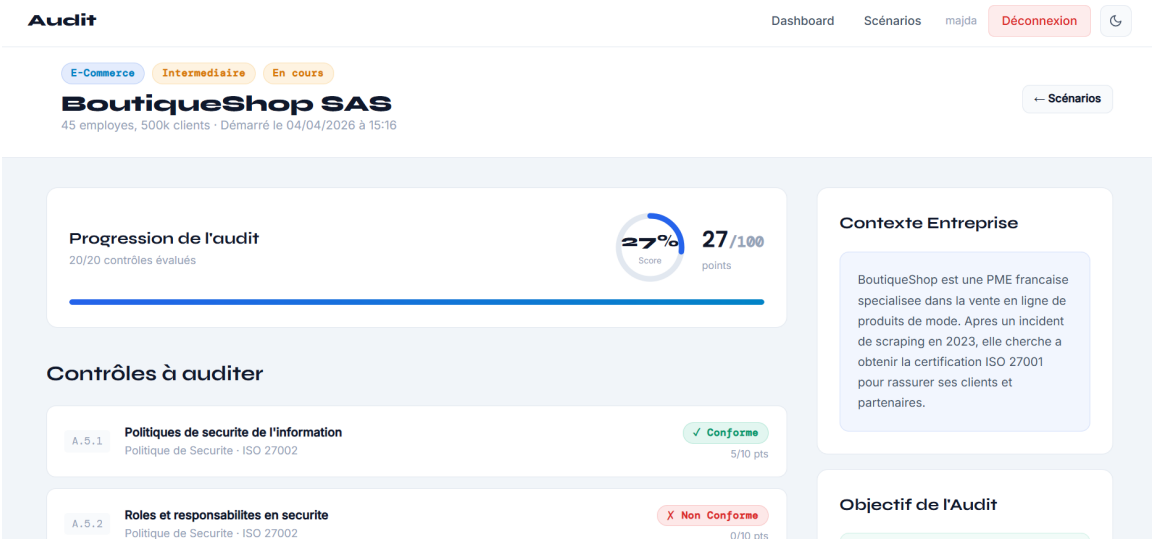

FIGURE V.10 – Vue d'ensemble après completion – 20/20 contrôles évalués, score 27/100

8. Finalisation de l'Audit

Une fois les 20 contrôles évalués, un message de confirmation « **Tous les contrôles ont été évalués !** » apparaît en bas de la page. L'auditeur peut alors cliquer sur le bouton « **Finaliser l'audit et générer le rapport** » pour clôturer la session et accéder au rapport d'audit complet. Les derniers contrôles de la liste affichent leurs statuts respectifs : « Non Conforme » pour A.8.24 (Utilisation de la cryptographie) et « N/A » pour A.5.29 et A.5.31.

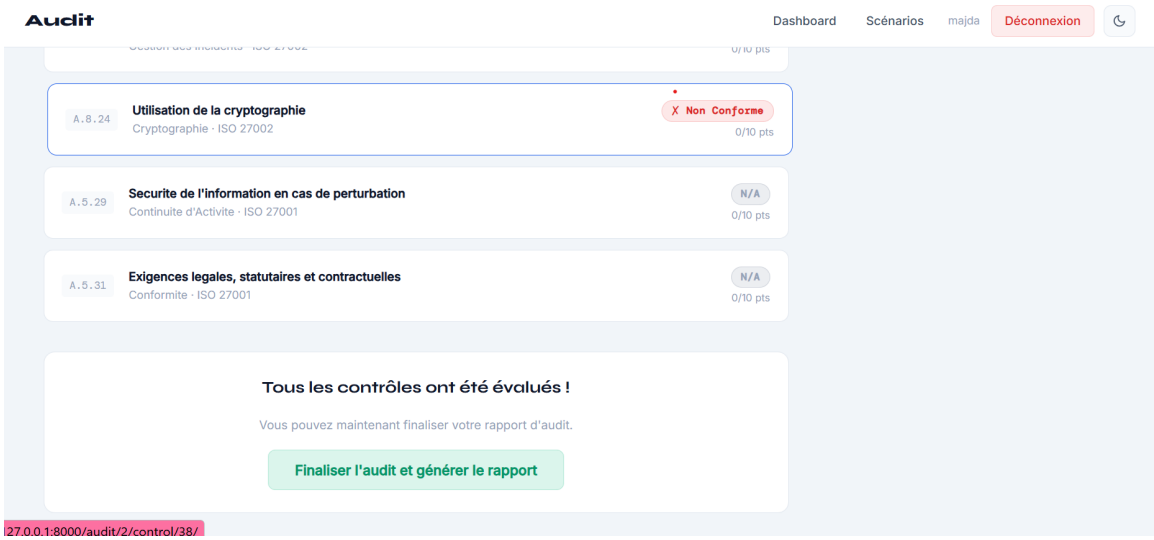

FIGURE V.11 – Fin de l'audit – bouton de finalisation et génération du rapport

9. Rapport d'Audit Final

Après finalisation, l'application génère automatiquement un rapport d'audit complet. Le **verdict global** est affiché en haut de la page avec le score obtenu. Dans cet exemple, l'auditeur a obtenu **27/100 points (27%)**, ce qui correspond au verdict **Non-Conformité Critique**, signifiant que des actions correctives urgentes sont nécessaires.

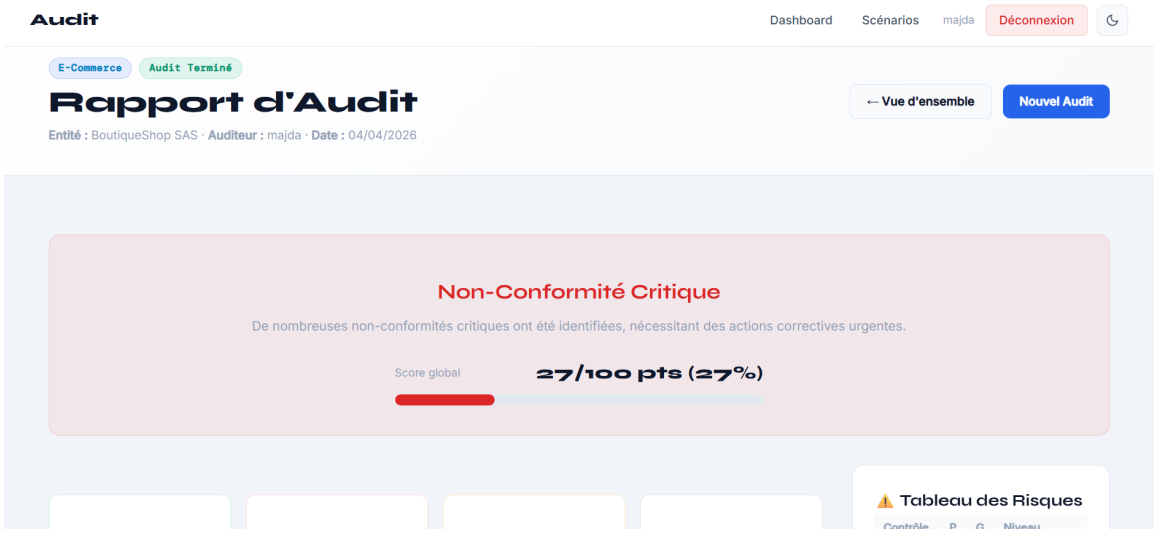

FIGURE V.12 – Rapport d'audit – verdict global Non-Conformité Critique, score 27/100

Le rapport présente ensuite une synthèse chiffrée de la répartition des conformités : **7 conformes**, **8 non conformes**, **3 partiels** et **2 N/A**, accompagnée d'un graphique en barres horizontales. Le **tableau des risques** latéral recense les contrôles non conformes avec leur probabilité (P), gravité (G) et niveau de risque associé (Faible, Moyen, Élevé, Critique).

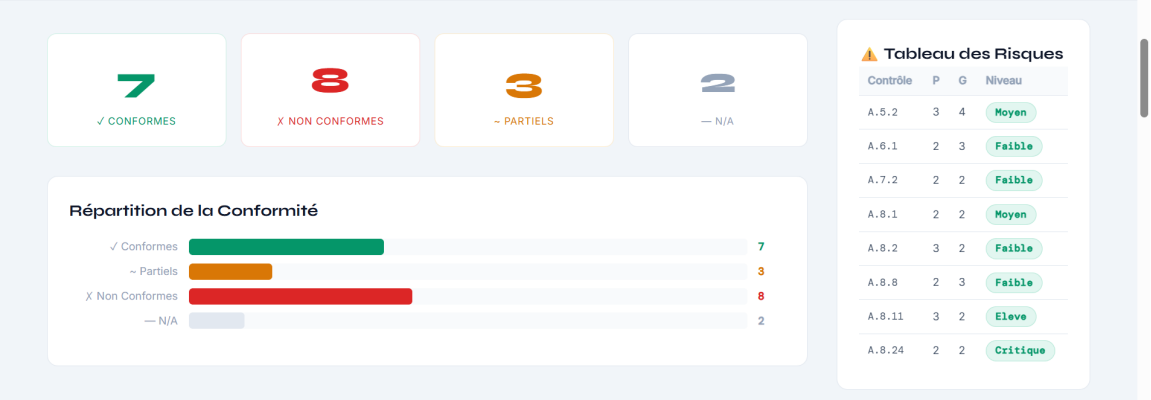

FIGURE V.13 – Répartition de la conformité et tableau des risques ISO 27005

Enfin, la section **Détail des Constatations** liste chaque contrôle avec son statut, ses points obtenus et le niveau de risque évalué selon la méthodologie ISO 27005 (probabilité × gravité). Les métadonnées de l'audit (référentiel, auditeur, date, entité) sont également affichées dans le panneau latéral.

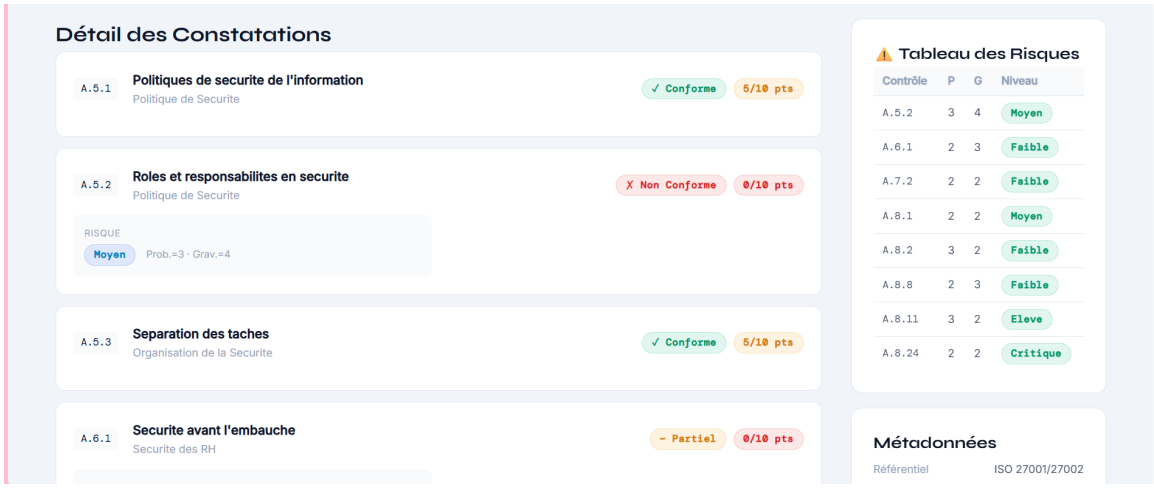

FIGURE V.14 – Détail des constatations avec statuts, points et niveaux de risque

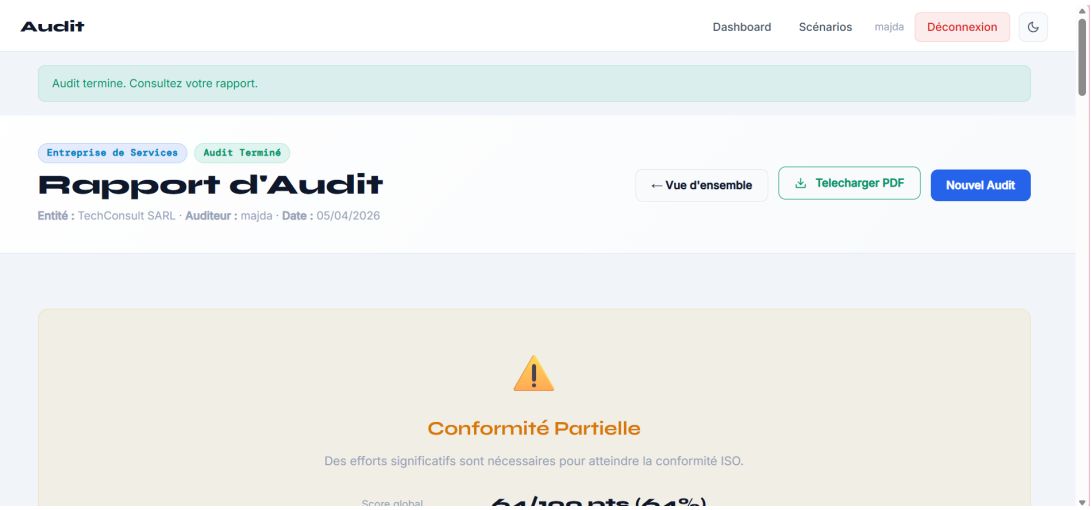

FIGURE V.15 – Interface web du rapport d'audit avec bouton Telecharger PDF – scenario TechConsult SARL

La figure V.15 presente la page du rapport d'audit apres finalisation d'une session sur le scenario **TechConsult SARL**. On distingue le bouton « **Telecharger PDF** » permettant l'export du rapport, ainsi que le verdict global « **Conformite Partielle** » avec un score de **64/100 points (64%)**. Les metadonnees de l'audit sont egalement affichees : entite auditee, auditeur, date et referentiel ISO utilise.

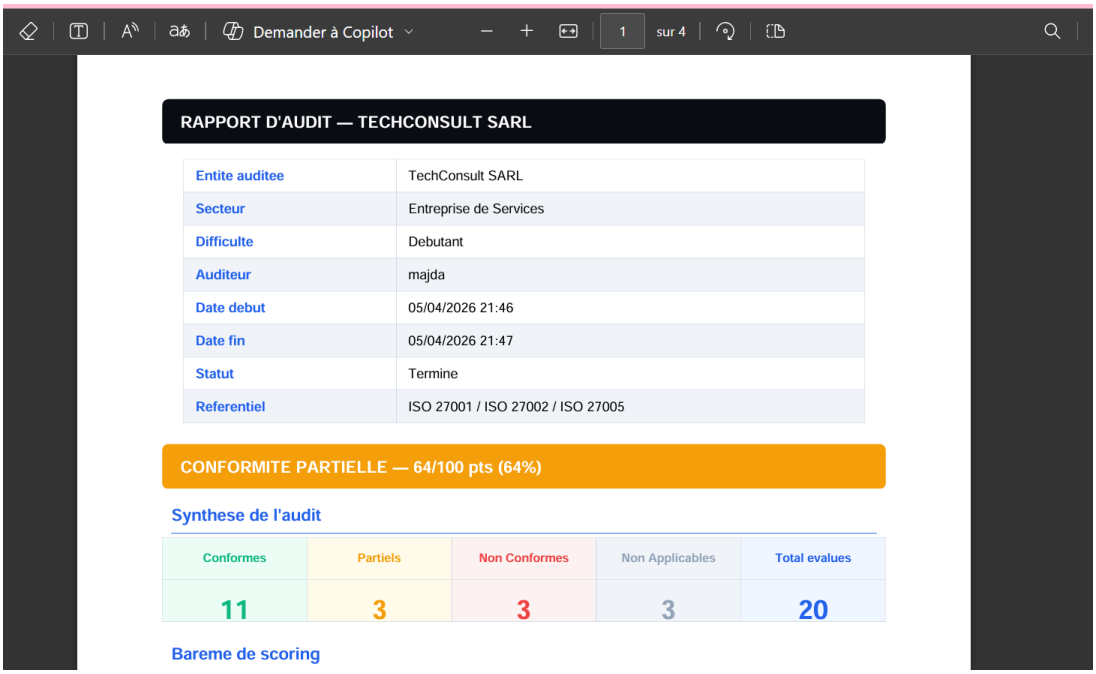

FIGURE V.16 – Rapport PDF genere automatiquement – TechConsult SARL

La figure V.16 presente le rapport PDF genere automatiquement par l'application. Il contient les metadonnees completes de l'audit, le verdict global « **Conformite Partielle – 64/100 pts (64%)** », ainsi que la synthese presentant les **11 controles conformes**,

3 partiels, **3 non conformes** et **3 non applicables** sur un total de **20 controles evalues**.

Conclusion

Ce projet nous a permis de concevoir et de développer une application web pédagogique complète répondant aux objectifs fixés dans le cahier des charges. *Learn⇒Audit* offre aux futurs auditeurs un environnement interactif et réaliste pour s'exercer aux techniques d'audit de conformité ISO 2700x, sans risque et avec un retour immédiat sur leurs décisions.

Le développement de ce projet nous a permis de renforcer nos compétences aussi bien sur le plan technique (Django, Python, JavaScript, base de données) que sur le plan méthodologique (conception d'un modèle de données, architecture MVT, gestion des sessions utilisateur).

Les perspectives d'évolution sont nombreuses, notamment l'ajout de nouveaux scénarios, l'intégration de nouveaux référentiels (RGPD, NIS2, PCI-DSS) et l'export du rapport d'audit en PDF.

Références

— ISO/IEC 27001 :2022 – Systèmes de management de la sécurité de l'information

— ISO/IEC 27002 :2022 – Mesures de sécurité de l'information

— ISO/IEC 27005 :2022 – Gestion des risques liés à la sécurité de l'information

— Documentation officielle Django 4.2 – https://docs.djangoproject.com

— Python 3.12 Documentation – https://docs.python.org